

Essential Fraud Readiness Review

An evidence-linked view of reported readiness, material risk, control priorities and leadership decisions.

PREPARED EXCLUSIVELY FOR

Vhutshilo Foods Manufacturing (Pty) Ltd

Report reference RPT-MKFRS-V12-COMP-VHUTSHILO-V1
Generated 23 August 2026
Essential package

CONFIDENTIAL · INTERNAL LEADERSHIP USE

Contents

Executive summary	3
What the result means	4
Domain overview	6
Priority findings, contradictions and scenarios	8
Priority risks	14
Leadership decisions and roadmap	17
Proof requirements	22
Methodology, limitations and next steps	23
Appendix: supporting material	23
Complete supporting detail	23
E1. Supporting control actions	23
E2. Definitions and score basis	26

Executive summary

Fraud controls are not yet consistently embedded.

Reported readiness

43

out of 100

Developing

Overall readiness position

The assessment places Vhutshilo Foods Manufacturing at 43.33 out of 100 with a Developing maturity. That position reflects weaker capability across several operational and digital domains. Domains where the assessment records lower positions include Digital and Identity Fraud Risk, Fraud Risk Identification, Operational Fraud Controls and Fraud Detection Capability; these weaker areas are the principal constraints on overall readiness. The position is an advisory synthesis of management’s own responses and the MK scoring method; it is strategic fraud-risk analysis and control design, not independent verification of operating effectiveness.

What is shaping the readiness position

Beneath the numeric score sits a connected pattern of capability gaps. Process-level fraud mapping and governance discipline are not yet consistently applied, so operational exposures are not fully owned or refreshed as processes change. Privileged and ordinary access governance is at an informal or partly designed state, reducing confidence that sensitive rights are limited, logged and periodically recertified. Supplier onboarding and related payment-instruction checks are partly designed, leaving a gap between verification intent and consistent pre-activation assurance. Detection capability shows partial design: rule-based analytics and tuned checks exist in principle but are not consistently executed or tuned. Finally, incident response and evidence-preservation arrangements are informal and reactive in practice, reducing the organisation’s ability to contain and learn from suspected matters. Together these themes form an interdependent readiness picture: weak foundations in governance and process mapping limit the effective design and operation of access, supplier and detection controls, and leave incident handling and evidence integrity exposed.

What this means for management

The assessed position is a practical starting point for management action rather than a statement that controls are absent. Management should treat the score as a roadmap: assign accountable executives, prioritise the process-level fraud map and supplier verification measures first, and sequence privileged-access and detection improvements to reduce the highest-probability pathways. Immediate governance decisions are required to name ownership, confirm remediation versus time-bound acceptance, approve control standards and resource the highest-complexity items so that the control improvements can be delivered and measured.

COVERAGE	CRITICAL GAPS	MAJOR GAPS
100%	6	3

Assessment scope and limitations

APPLICABLE CONTROLS	CONTROL VISIBILITY	EXCLUDED AREAS	UNCERTAINTY RESPONSES
60	100%	8	0

The result reflects the control areas applicable to the organisation. Valid scope exclusions and oversight-routed controls are part of the adaptive assessment design; differences in assessed scope

may limit direct comparison with other assessments.

4 control areas were completed using the assessment's oversight question set rather than the standard question set. They remain in the scored scope. Excluded areas are outside the assessed scope and are not treated as weaknesses.

The aggregate result and its ten underlying domains

The Developing result describes the reported self-assessment position. It does not, by itself, establish operating effectiveness.

Fraud Leadership and Governance 42 Developing	Fraud Risk Identification 39 Reactive	Operational Fraud Controls 41 Developing	Fraud Detection Capability 41 Developing	Fraud Incident Response 44 Developing
Whistleblowing and Reporting Culture 61 Structured	Third-Party and Supply Chain Fraud Risk 47 Developing	Digital and Identity Fraud Risk 38 Reactive	Fraud Culture and Awareness 57 Developing	Continuous Improvement and Fraud Risk Monitoring 41 Developing

What the result means

The recorded conditions requiring first attention

CRITICAL CONTROL GAP · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation’s important processes.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS

The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · OPERATIONAL FRAUD CONTROLS

System and data access is granted against current role requirements.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD DETECTION CAPABILITY

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · FRAUD INCIDENT RESPONSE

Evidence linked to suspected fraud is identified, preserved and handled appropriately.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

CRITICAL CONTROL GAP · DIGITAL AND IDENTITY FRAUD RISK

Access to sensitive systems, administrator rights and confidential data is restricted.

This recorded condition is considered in the diagnosis, priority findings, risks and roadmap that follow where it is material to the executive priority set.

Where a strong average can still hide a real gap

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Fraud risks are mapped to the organisation's important processes.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · OPERATIONAL FRAUD CONTROLS

Supplier onboarding verifies business identity, ownership and initial banking information before approval.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · CROSS-DOMAIN

Three or more critical controls scored 0, 1 or 2.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

MATURITY CEILING · FRAUD RISK IDENTIFICATION

Core domain Fraud Risk Identification scored below 40.

This rule sets a maximum maturity of **Developing**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Core domain Fraud Leadership and Governance scored below 60.

This rule sets a maximum maturity of **Structured**. More than one ceiling may apply at the same time; the strictest applicable ceiling governs the final maturity. The recorded condition remains subject to the operating proof specified in this report.

Management response: see the leadership roadmap section for accountable executive mandates, escalation authority and the fraud-risk implementation and control-effectiveness review cadence.

A domain score is an average. It can still contain one specific control that is materially weaker than the others feeding into the same number. The purpose of this report is to surface that unevenness so leadership does not treat the overall score as a substitute for control-level attention.

DOMAIN OVERVIEW

Domain overview

The systemic pattern

The dominant systemic constraint is a gap between organisation-level intent and process-level ownership. Fraud risks are not consistently mapped to each material, value-bearing process; where mapping is informal or reactive, process-level scenarios and associated controls lack named owners and signed acceptance. That gap weakens the ability to prioritise and fund targeted fixes, and it allows supplier, access and monitoring weaknesses to persist in specific processes.

Access governance and recertification are another systemic enabler of exposure. Privileged and ordinary access controls are either informal or partly designed, which creates a potential path for sensitive-account misuse or stale rights to be used to alter records or conceal activity. Where access and segregation controls are incomplete, detection rules and exception review are the only remaining barriers; however, those detection capabilities are themselves only partly designed and require a managed catalogue, reconciled data sources and monthly tuning to be reliable.

Supplier and payment integrity weaknesses sit across procurement and vendor-master processes and are materially linked to the access and detection gaps. Incomplete pre-activation supplier verification and inconsistent conflict-of-interest declarations create a route for fictitious or conflicted suppliers to enter the vendor population, which in turn requires robust independent verification and second-person review to interrupt.

Finally, incident-response and evidence-preservation arrangements are informal, reactive and not consistently applied. That condition means suspected matters risk having incomplete custody trails, which complicates containment, investigation and any recovery or corrective learning. The governance deficiency — lacking a repeatable, resourced rhythm that maps risks to processes and owners — is the common enabling factor across these operational weaknesses.

Foundations: ownership, awareness and reporting culture

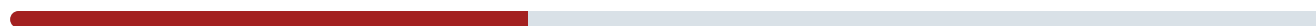
Executive ownership, risk identification, workforce awareness and safe reporting.

Fraud Leadership and Governance**42/100**

Developing reported position.

Fraud Risk Identification

39/100



Reactive reported position.

Critical condition: Fraud risks are mapped to the organisation's important processes.

Fraud Culture and Awareness

57/100



Developing reported position.

Whistleblowing and Reporting Culture

61/100



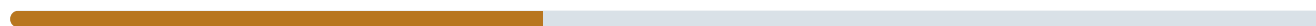
Structured reported position.

Operational defence: controls, detection and third parties

Day-to-day prevention, detection and supplier-facing control operation.

Operational Fraud Controls

41/100



Developing reported position.

Priority condition: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

Critical condition: System and data access is granted against current role requirements.

Fraud Detection Capability

41/100

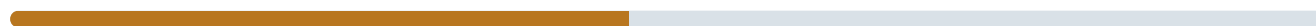


Developing reported position.

Priority condition: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

Third-Party and Supply Chain Fraud Risk

47/100



Developing reported position.

Response and evolution: incidents, digital risk and improvement

Incident response, digital and identity defence, and continuous control improvement.

Fraud Incident Response

44/100



Developing reported position.

Priority condition: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

Digital and Identity Fraud Risk

38/100

Reactive reported position.

Priority condition: Access to sensitive systems, administrator rights and confidential data is restricted.

Continuous Improvement and Fraud Risk Monitoring

41/100

Developing reported position.

PRIORITY FINDINGS, CONTRADICTIONS AND SCENARIOS

Priority findings, contradictions and scenarios

8 conditions were selected for executive attention from 25 recorded findings. The complete register of all 25 findings is provided in the Essential Supporting Register (RPT-MKFRS-V12-COMP-VHUTSHILO-V1-supporting-register.xlsx).

Role distinction: Control owner identifies the role responsible for implementing or operating the control. Accountable executive identifies the executive role responsible for sponsorship, decision rights and escalation. The two roles may legitimately differ.

Value diversion through supplier and payment processes

Supplier onboarding and bank-detail verification are only partly designed. The organisation's current supplier-activation practice does not consistently retain pre-activation evidence packages or require an independent second reviewer before ERP activation. That gap creates an exposure where a fictitious, misrepresented or conflicted supplier can be used to route invoices or payments without the independent verification required to detect the compromise. Management must ensure independent verification before any supplier activation or bank-detail change takes effect; without that pause-and-confirm discipline, diversion through supplier relationships can continue unchallenged.

Weak challenge at identity, transaction and sensitive-change points

Analytics and rule-based detection, together with escalation criteria, are only partly designed. The available detection tests do not yet map every priority fraud scenario to an operating check with monthly tuning and a named reviewing role. In this environment, unusual transactions, approval-pattern anomalies or near-duplicate payments can remain below timely challenge because exception review and escalation are not formalised. Management should adopt a defined monitoring cycle with named exception reviewers and explicit escalation criteria; absent that, flagged anomalies are at risk of being delayed or unresolved.

Limited containment and learning after suspected fraud

Evidence preservation and chain-of-custody arrangements are informal or reactive. When a suspected matter arises, there is not yet a consistently applied process for opening an evidence register, creating forensic copies or sealed originals, recording hash or seal numbers and logging every transfer. That deficiency increases the risk that material records will be altered, lost or rendered unusable for investigation and recovery. Management must define an intake and preservation route from the first report and ensure trained custodians and secure repositories are available; without a controlled custody route at first report, containment and subsequent learning remain impaired.

Additional material control pattern

A set of related control observations sits across privileged access, role-based access, conflicts of interest and reporting awareness. Privileged and administrator access governance is informal; role-based access is partly designed with incomplete role-to-access matrices and segregation exceptions; conflict-of-interest declaration for supplier relationships is informal and reactive; and workforce ability to use the reporting channel is partly designed. Together these observations highlight that privileged and ordinary access, third-party oversight and reporting culture must be reconciled to current responsibilities, periodically recertified and tested. The completion test for these items is named privileged accounts with periodic recertification and a reconciled role-to-access inventory; without that discipline, stale or excessive rights and undisclosed conflicts remain unchallenged.

Fraud Risk Identification: Fraud risks are mapped to the organisation's important processes.

DOMAIN

Fraud Risk Identification

DIAGNOSIS

Process-level fraud risk mapping was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Fraud risks are mapped to the organisation's important processes. — Informal / reactive

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Risk / compliance accountable owner with named process owners

IMPLEMENTATION

Moderate difficulty · 90 days

Operational Fraud Controls: The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf.

DOMAIN

Operational Fraud Controls

DIAGNOSIS

Supplier-onboarding verification was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf. — Partly designed

WHY IT MATTERS

This is a maturity-limiting control condition. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Procurement / Vendor Master

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 3

PRIORITY CONTROL WEAKNESS

Digital and Identity Fraud Risk: Access to sensitive systems, administrator rights and confidential data is restricted.

DOMAIN

Digital and Identity Fraud Risk

DIAGNOSIS

Privileged and administrator access governance was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Access to sensitive systems, administrator rights and confidential data is restricted. — Informal / reactive

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Identity and Access Management

IMPLEMENTATION

High difficulty · 60 days

MATERIAL FINDING 4

PRIORITY CONTROL WEAKNESS

Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

DOMAIN

Fraud Incident Response

DIAGNOSIS

Fraud evidence preservation and chain of custody was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Evidence linked to suspected fraud is identified, preserved and handled appropriately. — Informal / reactive

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Investigation lead / Evidence custodian

IMPLEMENTATION

High difficulty · 60 days

Operational Fraud Controls: System and data access is granted against current role requirements.

DOMAIN

Operational Fraud Controls

DIAGNOSIS

Role-based user-access governance was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

System and data access is granted against current role requirements. — Partly designed

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Business system owners

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 6

PRIORITY CONTROL WEAKNESS

Fraud Detection Capability: Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions.

DOMAIN

Fraud Detection Capability

DIAGNOSIS

Analytics and rule-based detection was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions. — Partly designed

WHY IT MATTERS

This is a priority control weakness under the MK methodology. Management should implement the recommended control and obtain the specified operating proof before treating the condition as resolved or relying on a higher maturity position.

CONTROL OWNER

Fraud analytics owner

IMPLEMENTATION

High difficulty · 90 days

MATERIAL FINDING 7

CROSS-DOMAIN DEPENDENCY

Third-Party and Supply Chain Fraud Risk: Employees are required to disclose and manage conflicts of interest involving suppliers or third parties.

DOMAIN

Third-Party and Supply Chain Fraud Risk

DIAGNOSIS

Conflict of interest declaration and management was self-assessed as "Informal / reactive" (Some activity occurs, but it is informal, reactive or dependent on individual effort; normalised score 20/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.

ASSESSED CONTROL STATE

Employees are required to disclose and manage conflicts of interest involving suppliers or third parties. — Informal / reactive

WHY IT MATTERS

This recorded response and its surrounding exposure make the control materially relevant.

CONTROL OWNER

Compliance with Human Resources

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Legal / investigations accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

IMPLEMENTATION

Moderate difficulty · 60 days

MATERIAL FINDING 8

CROSS-DOMAIN DEPENDENCY

Whistleblowing and Reporting Culture: Employees know how to recognise suspected fraud and use the reporting channel.

DOMAIN

Whistleblowing and Reporting Culture

DIAGNOSIS

Workforce ability to use the reporting channel was self-assessed as "Partly designed" (The capability has been partly designed, but important elements are incomplete or inconsistent; normalised score 40/100). This is self-reported and requires the listed operating evidence before it can be treated as verified.

RECOMMENDED CONTROL

The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.

ACCOUNTABLE EXECUTIVE

People / workforce accountable owner

REMAINING LIMITATION

Self-reported assessment response only; no document, interview, transaction sample or system evidence has been independently verified.

ASSESSED CONTROL STATE

Employees know how to recognise suspected fraud and use the reporting channel. — Partly designed

WHY IT MATTERS

This recorded response and its surrounding exposure make the control materially relevant.

CONTROL OWNER

Ethics / Compliance lead

IMPLEMENTATION

Low difficulty · 60 days

Contradictions

CONTRADICTION 1

Operational and privileged-access weaknesses indicate one systemic access-governance issue

WHAT THE ASSESSMENT SHOWS

Digital and Identity Fraud Risk — Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort; Operational Fraud Controls — Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

WHY IT MATTERS

Excess access across ordinary and privileged environments can create an end-to-end manipulation and concealment route.

LEADERSHIP VERIFICATION

Is one complete identity, role and recertification population used across ordinary and privileged access reviews?

Scenarios and assurance tests

Conditional exposure pathways

These pathways are illustrative, conditional management tests intended to show where control response must interrupt a sequence. They are not allegations of an event but practical scenarios that emerge when the recorded control weaknesses combine with ordinary operating activities.

SUPPLIER OR PAYMENT INSTRUCTION IS DIVERTED THROUGH A COMPROMISED OR FICTITIOUS RELATIONSHIP

A supplier or bank-detail amendment made shortly before a scheduled payment can be used as an entry point when supplier onboarding and bank verification are not consistently performed before activation. The current environment's partly designed supplier-onboarding capability means a new or reactivated supplier may be present in the vendor master without a complete pre-activation evidence pack or second-reviewer approval. Warning indicators include a bank-detail change shortly before payment, a new supplier activated just prior to transactions, or an urgent payment request that seeks to bypass established callback verification. Immediate containment is to pause the affected supplier or payment instruction, independently confirm the trusted beneficiary details and preserve the approval trail. Longer-term response is to implement independent supplier and bank-detail verification, require dual approval before activation or payment, and monitor the vendor population for abnormal additions or changes.

PRIVILEGED ACCESS IS USED TO ALTER A VALUE-BEARING RECORD, ENTITLEMENT OR AUDIT TRAIL

Where privileged and administrator accounts are not fully restricted, logged and recertified, a usable privileged account can remain viable without accountable quarterly recertification. The entry point is an outstanding privileged entitlement or an emergency/admin account that is still active. Warning indicators include emergency administrator activity outside normal role patterns, unusual entitlement or audit-trail changes, or recertification exceptions that remain overdue. Immediate containment is to suspend or restrict the affected entitlement, preserve the access and audit logs, and route the affected change for accountable review. The longer-term response is to enforce least-privilege role design, privileged-session logging, named business justification for each privileged account and routine independent recertification with removal tickets processed promptly.

RECORDS OR REPORTING ARE WEAKENED AFTER A SUSPECTED FRAUD MATTER, ALLOWING EXPOSURE TO REPEAT

When evidence identification, preservation and custody are informal, a suspected matter that generates records before a retention or legal-hold decision can be compromised. The entry point is the initial incident reporting or an exception that creates relevant records; without a clear custody route, transfers or ad hoc handling can fragment or alter those records. Warning indicators include unreconciled incident or access records, unexplained custody gaps, or severity decisions that remain overdue. Immediate containment is to open an incident record, preserve relevant records under controlled custody and assign a named containment and investigation owner. Longer-term response is to implement protected reporting channels, defined severity-based escalation, formal evidence preservation procedures and a repeat-exposure review so lessons convert into preventive control changes.

PRIORITY RISKS

Priority risks

Risk priority is produced by the MK qualitative likelihood/impact matrix. Risks sharing the same priority class are not more finely ranked by their display order. Likelihood and impact are qualitative descriptors, not statistical probabilities. The complete risk register (24 risks) is provided in the Essential Supporting Register (RPT-MKFRS-V12-COMP-VHUTSHILO-V1-supporting-register.xlsx).

RISK 1 · FRAUD RISK IDENTIFICATION

CRITICAL

Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as stock write-off manipulation is never mapped to a control owner.

Because the self-assessment records "Fraud risks are mapped to the organisation's important processes" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that organisation-level risk statements hide process-level opportunity, so a specific diversion route such as stock write-off manipulation is never mapped to a control owner. Consequence pathway: Material process exposures can remain without explicit control ownership or treatment; Unmapped process-level fraud routes can leave value diversion or loss outside targeted controls.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Risk Identification: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

REQUIRED TREATMENT

The Risk / compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

TARGET PERIOD

90 days

RISK 2 · FRAUD DETECTION CAPABILITY

CRITICAL

As transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation.

Because the self-assessment records "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that as transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Detection Capability: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner / Technology / security accountable owner

TARGET PERIOD

90 days

RISK 3 · FRAUD INCIDENT RESPONSE

CRITICAL

Fraud evidence loses integrity or chain of custody

Because evidence identification, preservation, integrity checks and custody transfers are not consistently controlled, there is a risk that material evidence is altered, lost, contaminated or cannot be shown to be authentic. Consequence pathway: evidence, retention or legal-hold duties may be breached; investigations must be repeated or abandoned; recovery, disciplinary or legal outcomes are weakened; the organisation cannot substantiate its response.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

High — High impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Fraud Incident Response: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort

REQUIRED TREATMENT

The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.

ACCOUNTABLE EXECUTIVE

Legal / investigations accountable owner / Finance / operations accountable owner

TARGET PERIOD

60 days

RISK 4 · OPERATIONAL FRAUD CONTROLS

CRITICAL

Fictitious or conflicted supplier enters the vendor population

Because supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation, there is a risk that a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment. Consequence pathway: funds are paid to an illegitimate or related party; procurement and vendor-master integrity are compromised; sanctions, conflict or procurement obligations may be breached; stakeholders lose confidence in supplier governance.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.

ACCOUNTABLE EXECUTIVE

Finance / operations accountable owner

TARGET PERIOD

60 days

RISK 5 · OPERATIONAL FRAUD CONTROLS, DIGITAL AND IDENTITY FRAUD RISK

CRITICAL

Unauthorised system access enables transaction or record manipulation

Because privileged, administrator or sensitive-data access is not completely restricted, logged and independently recertified, there is a risk that a privileged user or compromised administrator identity alters records, controls or logs without timely detection. Consequence pathway: confidence in digital controls is damaged; critical systems and audit trails lose integrity; high-impact transactions or data can be manipulated; security and personal-data obligations may be breached.

LIKELIHOOD

High — The self-assessment records a hard-gate or maturity-limiting weakness with a very low response; this supports a High qualitative likelihood, not a statistical probability.

IMPACT

Severe — Severe impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Digital and Identity Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort; Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

ACCOUNTABLE EXECUTIVE

Technology / security accountable owner

REQUIRED TREATMENT

IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control. System owners must maintain a current role-to-access matrix, require business-owner approval against the requester’s current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.

TARGET PERIOD

60 days

RISK 6 · WHISTLEBLOWING AND REPORTING CULTURE

MEDIUM

A channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud.

Because the self-assessment records "Employees know how to recognise suspected fraud and use the reporting channel" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that a channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud. Consequence pathway: Early-warning information may never reach an independent reviewer; suppressed reporting lets fraud continue longer.

LIKELIHOOD

Moderate — Critical-control, scenario or dependency evidence supports a Moderate qualitative likelihood, not a statistical probability.

IMPACT

Moderate — Moderate impact reflects the plausible consequence pathway and the critical, hard-gate and cap evidence linked to the consolidated findings.

CURRENT CONTROL POSITION

Whistleblowing and Reporting Culture: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent

REQUIRED TREATMENT

The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.

ACCOUNTABLE EXECUTIVE

People / workforce accountable owner

TARGET PERIOD

60 days

LEADERSHIP DECISIONS AND ROADMAP

Leadership decisions and roadmap

Target control environment

Strengthen fraud-risk identification and treatment

Target state: produce and maintain a per-process fraud map covering every material value-bearing process. Each map must record credible fraud scenarios, the roles and system permissions able to execute them in isolation or collusion, the preventive and detective controls relied upon, and any residual gap with a named treatment owner. The accountable executive is the finance/operations owner with the risk/compliance owner coordinating process owners; the completion test is 100% of material processes signed off with named controls and residual gaps. Management decisions to approve an accountable executive mandate, confirm remediation rather than passive acceptance, adopt control design standards and sequence dependent workstreams are required so that mapping is timely, resourced and actionable. These changes help ensure the organisation can prioritize and fund treatments where the fraud opportunity is process-specific rather than only organisation-level.

Strengthen supplier onboarding and identity checks

Target state: every supplier is verified before activation against legal identity, ownership, tax/banking information and conflict indicators, with enhanced review for high-risk suppliers. Procurement or the vendor master must retain the complete evidence package and a second-reviewer sign-off before any ERP activation. The completion test is that 100% of newly activated suppliers have a pre-activation evidence pack and independent approval. This control reduces the likelihood that a fictitious or conflicted supplier is used to divert payments and forms the first line of defence against supplier-based diversion pathways.

Strengthen privileged access and recertification

Target state: sensitive and privileged access is least-privilege, strongly authenticated, attributable, logged and limited to a justified business need, with quarterly independent recertification and event-driven removal for leavers. Identity and access management must maintain a privileged-account register, session logs and removal tickets as proof. Management should decide on funding and resource allocation for specialist capability where needed and require the quarterly recertification cadence; the completion test is quarterly recertification coverage, timely leaver removals and zero unjustified shared admin accounts. These changes reduce the window in which privileged access can be misused to alter records or conceal activity.

Strengthen monitoring, exception review and escalation

Target state: maintain a catalogue of detection rules and data checks that map each test to a fraud scenario, run against reconciled data and are tuned monthly from confirmed outcomes. The monitoring owner must define coverage, red flags and a named reviewing role for exceptions; escalation criteria and timeliness are explicit. Completion is measured by at least one operating data check for every priority fraud scenario and monthly tuning evidence. Management must fund delivery where analytic capability is constrained and approve the sequencing of prerequisite data and ownership tasks so monitoring outputs are reliable for investigators.

Strengthen evidence preservation and custody

Target state: evidence is collected under legal direction when needed, hashed or sealed, logged through every transfer, access-restricted and retained under an approved schedule. The investigation lead and designated evidence custodians must open an evidence register for material cases, record chain-of-custody details and escalate custody breaks immediately to Legal. The completion test is that sampled material-case evidence has a complete custody trail and matching integrity checks. These measures help preserve investigatory value and enable remediation, recovery or any legal process.

Strengthen role-based access and segregation

Target state: access requests are approved against a current role design and least-privilege basis before provisioning. Business system owners must maintain a role-to-access matrix, separate incompatible initiation and approval rights, and reconcile joiner/mover/leaver events to access provisioned. The completion test is quarterly population review and rapid closure of removal exceptions. This work reduces the number of stale or excessive ordinary-user rights that can be used to initiate or conceal fraudulent transactions.

Leadership decisions required

Every decision below carries a defined accountable executive role and a fixed target period; each is grounded in the material findings, risks and controls set out in this report and in the complete registers in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-VHUTSHILO-V1-supporting-register.xlsx).

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
1	Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	30 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
2	Choose and record remediation rather than passive acceptance for Critical and High risks.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	CEO / Managing Director	60 days	Known risk pathways remain untreated without a documented acceptance basis.

NO.	DECISION REQUIRED	RECOMMENDED DECISION	ACCOUNTABLE EXECUTIVE	TARGET PERIOD	CONSEQUENCE OF DELAY
3	Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	30 days	Partial or inconsistent designs fail to address the causal pathway.
4	Approve specialist capacity and resources for high-difficulty controls.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Finance / operations accountable owner	60 days	The highest-complexity gaps remain open despite nominal approval.
5	Approve prerequisite-first sequencing for dependent improvements.	Approve the prerequisite sequence and escalate threatened prerequisites.	CEO / Managing Director	30 days	Downstream controls are implemented on incomplete foundations.
6	Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	CEO / Managing Director	60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

30/60/90-day roadmap

The first 30 days establish decisions and ownership; the 60- and 90-day windows implement and evidence the linked controls.

By 30 days — Stabilise

Stabilise accountability and immediate containment practices by assigning accountable executives for the priority control responses, confirming escalation authority and establishing the incident-intake and evidence-preservation basics. In practice this requires implementing pre-activation supplier verification as an immediate control stop-gap and publishing the escalation route and decision-rights for incident triage. Proof of progress is the presence of completed onboarding checks and second-reviewer approvals for newly activated suppliers, and an incident-intake route that records initial custody and owner assignment.

First 30 days — decisions and foundations

PRIORITY DECISION	DELIVERABLE	ACCOUNTABLE EXECUTIVE	COMPLETION TEST
Approve accountable executive mandates and escalation authority for priority remediation.	Name one accountable executive per linked control and approve a 30-day escalation route.	CEO / Managing Director	Signed mandate names each accountable executive, decision rights and the escalation route.
Approve the target control standards management will implement across the priority risk areas.	Adopt the control-improvement register; deviations require documented oversight approval.	CEO / Managing Director	Approved control-improvement baseline records the required design standard and any authorised deviations.
Approve prerequisite-first sequencing for dependent improvements.	Approve the prerequisite sequence and escalate threatened prerequisites.	CEO / Managing Director	Dependency sequence is approved with named prerequisite owners and escalation for threatened dependencies.

First 30 days — implementation foundations

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any supplier activated before verification or any ownership/conflict match unresolved.	Finance / operations accountable owner	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.

By 60 days — Establish

Establish the priority preventive and access controls and the ownership and process changes that support them. Key deliverables in this window include reconciling privileged-account and role-to-access inventories, completing quarterly recertification schedules where feasible, closing initial removal tickets for leavers, and implementing evidence-preservation processes with an evidence register and chain-of-custody forms for material matters. The supplier pre-activation checklist must be operational across procurement, and conflict-of-interest declarations for in scope roles should be collected and tested against the vendor master. Success is evidenced by privileged-account registers, removal-ticket closure evidence, evidence-register entries for any new incidents and completed supplier onboarding evidence packs.

60-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Incident Response	Implement the target control design for Fraud Incident Response. Escalation trigger: Any unexplained custody gap, integrity mismatch or unauthorised repository access.	Legal / investigations accountable owner / Finance / operations accountable owner	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
Operational Fraud Controls	Implement the target control design for Operational Fraud Controls. Escalation trigger: Any missed quarterly review, unassigned account or removal overdue beyond 10 business days.	Finance / operations accountable owner	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
Digital and Identity Fraud Risk	Implement the target control design for Digital and Identity Fraud Risk. Escalation trigger: Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours.	Technology / security accountable owner	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
Third-Party and Supply Chain Fraud Risk	Implement the target control design for Third-Party and Supply Chain Fraud Risk. Escalation trigger: An employee-supplier match not investigated, or a declared conflict with no management action.	Finance / operations accountable owner / Legal / investigations accountable owner	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.
Whistleblowing and Reporting Culture	Implement the target control design for Whistleblowing and Reporting Culture. Escalation trigger: A failed channel test, or a site or language group below the awareness threshold.	People / workforce accountable owner	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.

By 90 days — Operate and review

Operate monitoring, exception review and control learning with consolidated progress reported to governance. The monitoring owner should show a rule catalogue with execution logs and monthly tuning records, and the fraud-risk mapping owner should deliver signed per-process fraud maps for the material population. Management should convene the approved implementation and control-effectiveness review cadence so remediation progress and testing of detection effectiveness are visible at executive and oversight levels. Proof of completion for the first cycle is reconciled execution logs, tuned detection outcomes, signed process fraud maps and a governance report consolidating exceptions, open remediations and any escalations.

90-day implementation actions

DOMAIN	DELIVERABLE	ACCOUNTABLE EXECUTIVE	SUCCESS MEASURE
Fraud Risk Identification	Implement the target control design for Fraud Risk Identification. Escalation trigger: Any material process unmapped, or a mapped residual gap with no owner.	Finance / operations accountable owner	100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.
Fraud Detection Capability	Implement the target control design for Fraud Detection Capability. Escalation trigger: A priority scenario with no operating check, or rules unexecuted for a full cycle.	Finance / operations accountable owner / Technology / security accountable owner	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.

Management conclusion

The assessment is a practical starting point: it highlights where existing relative strengths, notably the reporting channel, can be mobilised while the weaker domains need deliberate sequencing and ownership. Closing the gap requires named accountable executives, clear remediation decisions, funded delivery for higher-complexity controls, and a repeatable reporting cadence so that process-level fraud maps, supplier verification, access recertification, detection tuning and evidence preservation operate together. Making these items true in the first 90 days will convert the Developing maturity position into an organised remediation programme with measurable completion tests.

Proof requirements

The items below are the immediate proof requirements linked to the priority findings above. The complete evidence checklist is not reproduced in this report; it is provided in full in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-VHUTSHILO-V1-supporting-register.xlsx).

NO.	EVIDENCE ARTEFACT	WHAT IT PROVES	LIKELY OWNER	STATUS
1	Control linkage showing preventive and detective controls	Whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable.	Risk / compliance accountable owner with named process owners	Not yet requested
2	Per-process fraud scenario map	Whether each material process has explicit fraud scenarios, relevant roles or permissions and residual exposure documented.	Risk / compliance accountable owner with named process owners	Not yet requested
3	Process inventory identifying material value-bearing processes	Whether the complete population of material value-bearing processes has been identified before fraud-risk mapping is assessed.	Risk / compliance accountable owner with named process owners	Not yet requested
4	Process-owner sign-off	Whether process owners have reviewed and accepted the mapped fraud scenarios, control ownership and residual gaps.	Risk / compliance accountable owner with named process owners	Not yet requested
5	Beneficial-ownership/conflict screening	Whether proposed suppliers are screened for ownership and conflict indicators before activation and any exceptions are resolved or approved.	Procurement / Vendor Master	Not yet requested
6	Completed onboarding checklist	Whether the required supplier due-diligence checks were completed before activation for the in-scope supplier population.	Procurement / Vendor Master	Not yet requested
7	Independent registration and bank verification	Whether supplier legal identity and bank-account ownership were independently verified before activation or payment.	Procurement / Vendor Master	Not yet requested
8	Second-reviewer approval	Whether supplier activation or another high-risk change received the required independent second-person approval before release.	Procurement / Vendor Master	Not yet requested
9	Approval and business justification	Whether every privileged-access assignment in scope has an approved business justification, a named accountable owner and a documented basis for the level of access granted.	Identity and Access Management	Not yet requested
10	Privileged-account register	Whether the complete privileged-account population is recorded with account type, system, owner, privilege level, status and review date so that unknown or unjustified access can be identified.	Identity and Access Management	Not yet requested
11	Privileged-session/access logs	Whether privileged activity is attributable to named accounts and reviewable for unusual, unauthorised or out-of-pattern activity during the stated period.	Identity and Access Management	Not yet requested
12	Quarterly independent recertification	Whether the complete privileged-access population was independently reviewed on schedule, with explicit keep-or-remove decisions and unresolved exceptions identified.	Identity and Access Management	Not yet requested
13	Removal tickets	Whether access removals identified through recertification, role change or leaver events were completed within the required service level and are traceable to closure evidence.	Identity and Access Management	Not yet requested
14	Chain-of-custody forms	Whether each transfer of material evidence records custody, timing and handover without unexplained gaps.	Investigation lead / Evidence custodian	Not yet requested
15	Evidence register	Whether all material evidence items are uniquely recorded, assigned and traceable through the case.	Investigation lead / Evidence custodian	Not yet requested

Required population for every item: the complete in-scope population for the stated operating period, reconciled to the source system or register. Sampling expectation: review the complete population where feasible; otherwise use a documented risk-based sample including exceptions, changes and overdue

items. Every item begins with the status "Not yet requested"; status changes require a separately scoped review process outside this report. This remains a self-assessment: no document, interview, transaction sample or system evidence has been independently verified for any item.

METHODOLOGY, LIMITATIONS AND NEXT STEPS

Methodology, limitations and next steps

This report is generated from a structured self-assessment across ten fraud-risk-management domains. The score, maturity ceilings and advisory model use only the recorded assessment inputs and the MK Fraud Readiness methodology.

Limitations. This is not a forensic investigation, external audit, compliance certification or guarantee. Responses were not independently verified. Findings, scenarios and recommendations are decision-support material; leadership should obtain the specified operating proof before treating a control as effective or a finding as resolved.

Control design standard. Priority controls are specified by responsibility, population or scope, operating frequency, retained evidence, independent challenge, escalation trigger, service level, effectiveness measure and response to failure.

Companion register. The complete Essential delivery includes the Essential Supporting Register (RPT-MKFRS-V12-COMP-VHUTSHILO-V1-supporting-register.xlsx). It carries the complete finding, risk, control-action, evidence, roadmap and question-trace registers that are intentionally bounded in this PDF.

Assessment basis: submitted self-assessment responses and the MK Fraud Readiness methodology.

Recommended next step. Commission independent validation of the control linkage showing preventive and detective controls. Confirm whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable. This is the immediate proof priority; the complete sequence is set out in Proof requirements above and the full checklist in the companion Essential Supporting Register (RPT-MKFRS-V12-COMP-VHUTSHILO-V1-supporting-register.xlsx).

APPENDIX

Appendix: supporting material

Bounded supporting material for the priority matters above. The complete authoritative registers are provided in the supporting register, not reproduced here.

Complete supporting detail

This report presents the highest-priority matters from a complete assessment inventory of 68 controls (60 applicable and 8 excluded). The full assessment identified 25 material findings, 24 risks, 25 control improvements, 105 evidence artefacts, 25 recommended actions and 59 functional-agenda items.

Every item not shown in this report is retained in full in the Essential Supporting Register (RPT-MKFRS-V12-COMP-VHUTSHILO-V1-supporting-register.xlsx). No identified weakness has been discarded.

E1. Supporting control actions

Further control actions beyond the priority set above, in materiality order.

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
1	Operational Fraud Controls	Close the material control weakness recorded for "Transactions or operational activities above defined risk or value thresholds require independent review or approval".	The Finance / operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
2	Operational Fraud Controls	Close the material control weakness recorded for "People in high-risk roles are subject to appropriate oversight, rotation, secondary review or other compensating controls".	Human Resources and the Risk / compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	Finance / operations accountable owner / People / workforce accountable owner / 90 days
3	Fraud Detection Capability	Close the material control weakness recorded for "Exception reporting provides defined alerts for unusual transactions or activities and a documented review process".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	Finance / operations accountable owner / 60 days
4	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud and control misuse by people inside the organisation".	The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
5	Fraud Detection Capability	Close the material control weakness recorded for "Monitoring covers fraud threats from external parties relevant to the organisation".	The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	Finance / operations accountable owner / Technology / security accountable owner / 90 days
6	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	Finance / operations accountable owner / 90 days
7	Digital and Identity Fraud Risk	Close the material control weakness recorded for "Sensitive access and administrator rights are reviewed periodically".	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Technology / security accountable owner / 60 days
8	Operational Fraud Controls	Close the material control weakness recorded for "System and data access is reviewed periodically and removed when no longer required".	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
9	Operational Fraud Controls	Close the material control weakness recorded for "Payroll master-file changes and unusual payroll records receive review before payment".	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Finance / operations accountable owner / People / workforce accountable owner / 60 days
10	Operational Fraud Controls	Close the material control weakness recorded for "Physical cash is counted, safeguarded and reconciled by defined people".	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Finance / operations accountable owner / 60 days
11	Operational Fraud Controls	Close the material control weakness recorded for "Stock and physical assets are safeguarded and reconciled by defined people".	Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Finance / operations accountable owner / 90 days
12	Fraud Detection Capability	Close the material control weakness recorded for "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so".	The Risk / compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Governing body / independent oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Risk / compliance accountable owner / 30 days
13	Fraud Detection Capability	Close the material control weakness recorded for "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer".	The Governing body / independent oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Governing body / independent oversight / 90 days
14	Fraud Incident Response	Close the material control weakness recorded for "Roles and decision rights are defined for fraud triage, investigation, escalation and case closure".	The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	Finance / operations accountable owner / Legal / investigations accountable owner / 30 days
15	Fraud Incident Response	Close the material control weakness recorded for "External specialists are considered when incidents require forensic, legal, cyber or investigative expertise".	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	Legal / investigations accountable owner / Finance / operations accountable owner / 60 days

NO.	DOMAIN	CONTROL OBJECTIVE	CONTROL DESIGN	OWNER / TARGET
16	Whistleblowing and Reporting Culture	Close the material control weakness recorded for "Relevant external stakeholders have an appropriate way to report suspected fraud or misconduct".	The ethics owner must publish the external reporting route for each relevant stakeholder group, state confidentiality and anti-retaliation protections, restrict access to reports, route concerns away from implicated managers and monitor acknowledgement, triage and escalation times.	Governing body / independent oversight / CEO / 60 days
17	Third-Party and Supply Chain Fraud Risk	Close the material control weakness recorded for "The organisation receives and reviews risk information about high-risk third parties managed on its behalf".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance / operations accountable owner.	Finance / operations accountable owner / 90 days

E2. Definitions and score basis

How the score is calculated

Each applicable assessment response is normalised to a 0–100 control score and weighted within its domain. Domain scores are then combined using the methodology's domain weights to produce the overall readiness score. A control recorded as not applicable is excluded from its scoring denominator rather than treated as a weakness.

The weighted overall score is 43.33/100, which maps numerically to Developing. The final maturity shown in this report is Developing. The next numerical band begins at 60/100; a higher numerical score alone does not override a stricter applicable maturity ceiling.

Maturity scale

MATURITY	SCORE RANGE	INTERPRETATION
Reactive	0–<40	Foundational controls are limited or mainly reactive.
Developing	40–<60	Core control elements exist but are incomplete, inconsistent or not yet connected.
Structured	60–<80	Controls are more consistently defined, owned and operated.
Strategic	80–100	Fraud-risk management is embedded, monitored and continually improved.

Maturity ceilings

Maturity ceilings protect against a strong average masking a material weakness. A hard-gate critical control scored 0 or 1 sets a maximum of Developing; a hard-gate control scored 2 sets a maximum of Structured; three or more critical controls scored 0, 1 or 2 set a maximum of Developing; any core domain below 40 sets a maximum of Developing; and any core domain below 60 sets a maximum of Structured. Where several ceilings apply, the strictest ceiling governs the final maturity.

Reported domain scores

DOMAIN	REPORTED SCORE	MATURITY
Fraud Leadership and Governance	42/100	Developing
Fraud Risk Identification	39/100	Reactive
Operational Fraud Controls	41/100	Developing
Fraud Detection Capability	41/100	Developing
Fraud Incident Response	44/100	Developing
Whistleblowing and Reporting Culture	61/100	Structured
Third-Party and Supply Chain Fraud Risk	47/100	Developing
Digital and Identity Fraud Risk	38/100	Reactive
Fraud Culture and Awareness	57/100	Developing
Continuous Improvement and Fraud Risk Monitoring	41/100	Developing

Risk priority uses the MK qualitative likelihood/impact matrix. Risks in the same priority class are not further ranked by their display sequence. Priority and materiality are derived from assessment evidence; neither is an independent risk assessment.